

MARCO DOCUMENTAL DE SEGURIDAD

CloudHealth Canarias S.L.

— Actividad Práctica de Ciberseguridad —

Autora	María José Gómez Spandonari
Perfil	Alumna de Ciberseguridad
Empresa simulada	CloudHealth Canarias S.L.
Fecha	Mayo 2025
Clasificación	Uso educativo / Portfolio profesional

PARTE 1 — ANÁLISIS INICIAL

1.1 Activos críticos

Los activos críticos son aquellos recursos cuya pérdida, alteración o indisponibilidad tendría un impacto grave sobre la operativa de la clínica o sobre los derechos de los pacientes:

Tipo	Activo	Justificación
Datos	Historiales clínicos digitalizados	Datos de salud: categoría especial RGPD
Datos	Base de datos de pacientes y citas	Confidencialidad e integridad crítica
Sistema	Portal web de solicitud de citas	Disponibilidad del servicio al paciente
Sistema	Sistema de facturación online	Impacto económico directo
Infraest.	Almacenamiento cloud	Contiene documentación sensible
Infraest.	Tablets del personal sanitario	Acceso a historiales en movilidad
Infraest.	Acceso remoto de médicos	Vector de entrada si no es seguro
RRHH	Credenciales y cuentas de usuario	Puerta de entrada a todos los sistemas

1.2 Amenazas principales

- Ransomware y malware: ya materializado hace 6 meses en equipos administrativos.
- Acceso no autorizado mediante cuentas de antiguos empleados activas.
- Phishing y suplantación: especialmente dirigido al personal sin formación.
- Fugas de información por uso de USB personales no controlados.
- Compromiso de la cadena de suministro a través del proveedor externo de TI.
- Interceptación de accesos remotos por configuraciones inseguras.
- Acceso físico no controlado a dispositivos móviles (tablets).

1.3 Vulnerabilidades identificadas

Vulnerabilidad detectada	Nivel de riesgo	Evidencia en el escenario
Cuentas de exempleados activas	ALTO	Auditoría interna
Contraseñas débiles	ALTO	Auditoría interna
Uso de USB personales	ALTO	Auditoría interna
Ausencia de políticas formales documentadas	ALTO	No existe documentación
Falta de formación en ciberseguridad	MEDIO	Personal no concienciado
Escasa supervisión del proveedor externo	MEDIO	Sin SLA de seguridad
Acceso remoto sin política definida	MEDIO	Médicos con VPN no gestionada

1.4 Impacto de un incidente grave

Un incidente grave — como el ransomware ya sufrido o una brecha de datos clínicos — tendría consecuencias en cuatro dimensiones:

- **Impacto operativo.** Operativo: paralización de las consultas, imposibilidad de acceder a historiales y cancelación de citas.
- **Impacto legal.** Legal y regulatorio: sanción de la AEPD por incumplimiento del RGPD. Las multas pueden alcanzar 20 M€ o el 4% de la facturación global.
- **Impacto reputacional.** Reputacional: pérdida de confianza de pacientes y deterioro de la imagen de marca en un sector muy sensible.
- **Impacto económico.** Económico: costes de recuperación, posible rescate, sanciones, honorarios legales y lucro cesante.

1.5 Normativa y requisitos legales aplicables

- RGPD (Reglamento UE 2016/679): aplica por tratar datos de salud (categoría especial). Exige medidas técnicas y organizativas, registro de actividades y notificación de brechas en 72h.
- LOPDGDD (Ley Orgánica 3/2018): transpone el RGPD al ordenamiento español y añade requisitos específicos.
- Ley 41/2002 de autonomía del paciente: garantiza la confidencialidad del historial clínico.
- ENS — Esquema Nacional de Seguridad (Real Decreto 311/2022): aplicable si se prestan servicios a la Administración Pública o se gestiona información pública.
- ISO/IEC 27001: estándar de referencia para sistemas de gestión de seguridad de la información (SGSI). No es obligatorio por ley, pero altamente recomendable.
- NIS2 (Directiva UE 2022/2555): si la empresa se clasifica como entidad esencial o importante en el sector sanitario, deberá cumplir con sus requisitos de notificación y gestión de incidentes.

PARTE 2 — POLÍTICA GENERAL DE SEGURIDAD

OBJETIVO	Proteger la confidencialidad, integridad y disponibilidad de los datos de pacientes y sistemas de CloudHealth Canarias S.L., garantizando el cumplimiento normativo y la continuidad del servicio.
ALCANCE	Aplica a todos los empleados (80), trabajadores en teletrabajo, personal sanitario con tablets, proveedores externos y sistemas de información de ambas clínicas de Tenerife.
RESPONSABLES	- Dirección General: aprobación y respaldo estratégico. - Responsable de Seguridad (CISO / DPO): implantación, supervisión y cumplimiento. - Responsable TI / Proveedor externo: mantenimiento técnico de los controles. - Todos los empleados: cumplimiento de las políticas en su ámbito de trabajo.
PRINCIPIOS BÁSICOS	- Mínimo privilegio: acceso únicamente a los recursos necesarios para el desempeño del rol. - Necesidad de conocer: la información sensible solo se comparte con quien la necesita. - Defensa en profundidad: múltiples capas de control (técnico, organizativo, humano). - Mejora continua: revisión anual de políticas y controles.
CUMPLIMIENTO NORMATIVO	El incumplimiento de esta política podrá derivar en medidas disciplinarias internas y en responsabilidades legales conforme al RGPD, la LOPDGDD y la Ley 41/2002. La empresa garantiza el cumplimiento de toda la normativa aplicable.

PARTE 3 — POLÍTICAS ESPECÍFICAS PRIORITARIAS

Se seleccionan las 5 políticas más críticas para la situación actual de la empresa, justificadas por los riesgos identificados en el análisis inicial.

#	Política	Contenido clave	Justificación
1	Gestión de Identidades y Control de Acceso	MFA obligatorio, contraseñas de min. 12 car., baja inmediata al cesar relación laboral, revisión trimestral de cuentas.	Directamente relacionada con las cuentas de exempleados activas y contraseñas débiles detectadas.
2	Copias de Seguridad y Recuperación	Backups diarios cifrados, regla 3-2-1, pruebas de restauración trimestrales, air-gap para copias críticas.	El ransomware sufrido destruyó datos. Sin backups robustos no hay recuperación posible.
3	Uso Aceptable de Dispositivos y Medios Extraíbles	Prohibición de USB personales, uso exclusivo de dispositivos corporativos, cifrado de tablets, inventario de activos.	El uso de USB personales fue vector detectado. Las tablets con datos clínicos son activos críticos.
4	Gestión de Proveedores y Terceros	Cláusulas de seguridad en contratos, acceso restringido y auditado, evaluación anual, NDA firmado.	El proveedor de mantenimiento tiene acceso a sistemas internos sin supervisión documentada.
5	Formación y Concienciación en Ciberseguridad	Formación obligatoria anual, simulacros de phishing, módulos para teletrabajadores y personal sanitario.	La falta de formación es uno de los factores que facilitó el ataque ransomware.

PARTE 4 — PROCEDIMIENTO OPERATIVO: ALTAS Y BAJAS DE USUARIOS

Código	PRO-SEG-001
Versión	1.0
Fecha de aprobación	Mayo 2025
Responsable	Responsable de Seguridad / RRHH
Aplicable a	Todos los sistemas de CloudHealth Canarias S.L.

4.1 Objetivo y alcance

Garantizar que el acceso a los sistemas de información se gestiona de forma controlada y trazable, asegurando que solo los empleados en activo con necesidad justificada disponen de credenciales válidas.

4.2 Alta de usuario nuevo

Paso	Acción	Responsable	Plazo
1	RRHH notifica la incorporación mediante formulario de alta (F-SEG-001).	RRHH	Día -3 antes del inicio
2	El responsable de área indica los sistemas y permisos necesarios (principio de mínimo privilegio).	Responsable de área	Día -2
3	TI crea la cuenta con perfil restringido, activación de MFA y contraseña temporal de un solo uso.	TI / Proveedor	Día -1
4	El empleado firma el acuse de recibo de credenciales y la política de uso aceptable.	RRHH + Empleado	Día 1 (incorporación)
5	Se registra el alta en el inventario de cuentas de usuario (hoja de control).	TI	Día 1

4.3 Baja de usuario

Paso	Acción	Responsable	Plazo máximo
1	RRHH notifica la baja (despido, renuncia, fin de contrato) mediante formulario F-SEG-002.	RRHH	Mismo día de la decisión
2	TI deshabilita INMEDIATAMENTE todas las cuentas del empleado (correo, VPN, aplicaciones, cloud).	TI	Máx. 2 horas
3	Se redirigen los correos pendientes al responsable de área durante 30 días.	TI	Día de la baja
4	Se recuperan los dispositivos corporativos (tablet, ordenador, móvil) y se borran de forma segura.	RRHH + TI	Antes de la salida física

5	La cuenta pasa a estado «deshabilitada» durante 90 días y se elimina definitivamente pasado ese período.	TI	90 días post-baja
6	Se actualiza el inventario de cuentas y se notifica al Responsable de Seguridad.	TI	Día de la baja

4.4 Revisión periódica de cuentas

Con periodicidad trimestral el Responsable de Seguridad revisará el inventario completo de cuentas activas, cruzando con la lista de empleados de RRHH. Cualquier discrepancia se resolverá en un plazo máximo de 24 horas mediante deshabilitación preventiva.

PARTE 5 — INSTRUCCIÓN DE TRABAJO: GESTIÓN SEGURA DE HISTORIALES CLÍNICOS

Código	IT-SEG-005
Destinatarios	Personal sanitario con acceso a historiales clínicos
Soporte	Tablets corporativas y equipos de consulta
Revisión	Anual o tras incidente relevante

5.1 ¿Por qué es importante?

Los historiales clínicos son datos de categoría especial según el RGPD. Una brecha de confidencialidad puede vulnerar los derechos de los pacientes, generar sanciones graves y dañar la reputación de la clínica.

5.2 Reglas de uso — QUÉ DEBES HACER

✓	Acción obligatoria
✓	Accede al historial únicamente desde dispositivos corporativos de la clínica.
✓	Bloquea la pantalla (Windows + L o botón lateral en tablet) al alejarte del dispositivo, aunque sea por un momento.
✓	Cierra la sesión completa al finalizar la jornada o al ceder el dispositivo a otro profesional.
✓	Accede únicamente a los historiales de pacientes que estén bajo tu atención directa.
✓	Notifica de inmediato al Responsable de Seguridad cualquier acceso sospechoso o incidencia.

5.3 Reglas de uso — QUÉ NUNCA DEBES HACER

✗	Acción prohibida
✗	Compartir tu usuario y contraseña con ningún compañero, aunque sea de confianza.
✗	Copiar historiales en USB personales, correo personal o servicios de almacenamiento no autorizados (Google Drive personal, Dropbox, etc.).
✗	Fotografiar pantallas con el móvil personal, aunque sea para fines asistenciales.
✗	Dejar la tablet o el equipo desbloqueado y desatendido en zonas de paso o salas de espera.
✗	Acceder a historiales de familiares, conocidos o cualquier paciente que no esté asignado a tu atención.

5.4 Qué hacer si sospechas un incidente

Paso	Acción
1	No apagues ni toques el equipo afectado.
2	Llama al Responsable de Seguridad: ext. 200 / seguridad@cloudhealth-canarias.es
3	Anota la hora y lo que viste (mensaje de error, acceso extraño, datos modificados).
4	Espera instrucciones. No intentes resolverlo por tu cuenta.

Recuerda: la seguridad de los datos clínicos es responsabilidad de todos. Un descuido puede vulnerar la privacidad de cientos de pacientes.

